Роли пользователей и матрица доступа

Проект Т-Путешествия

1. Назначение документа

Документ определяет, какие пользователи могут просматривать и выполнять действия с участниками, расходами, долгами и активностями.

2. Какие роли есть в системе

Роли / состояние	**Что означает**
Зарегистрированный пользователь	Аккаунт с уникальным телефоном. Может управлять собственным профилем и создавать поездки. Доступ к конкретной поездке зависит от участия.
Организатор	Зарегистрированный пользователь, создавший поездку. Имеет полномочия управления участниками; подтверждает погашение долга за виртуального должника.
Участник	Зарегистрированный пользователь, принявший приглашение. Участвует в поездке и совместных расходах.
Виртуальный участник	Запись TripMember с userId = null и заполненным virtualName. Отдельного аккаунта и JWT нет; лично выполнять операции не может.

Роли Организатор и участник – роли внутри конкретной поездки, а не глобальные права во всем приложении. Один человек может быть организатор в одной поездке и участник в другой.

3. Матрица доступа: базовые действия

Обозначения: да – разрешено; нет – не предусмотрено; условно – только при соблюдении правила в примечании;

Любой зарегистрированный пользователь может изменять собственный профиль и создавать новые поездки независимо от своей роли в других поездках. Принятие приглашения доступно пользователю со статусом Pending. Остальные права зависят от роли и статуса участия в конкретной поездке.

Действие	Организатор	Участник	Приглашенный пользователь (Pending)	Виртуальный участник
Войти по SMS и изменить свой профиль	да	да	да	нет
Создать свою поездку	да	да	да	нет
Принять/отклонить личное приглашение	-	-	да	нет
Просмотреть данные поездки	да	да	нет	нет

Пригласить зарегистрированного пользователя	да	нет	нет	нет
Добавить виртуального участника	да	нет	нет	нет
Посмотреть участников и расходы поездки	да	да	нет	нет
Добавить расход с долями участников	да	да	нет	нет
Посмотреть баланс и историю поездки	да	да	нет	нет
Подтвердить собственный полный долг	условно	условно	нет	нет
Подтвердить долг виртуального должника	да	нет	нет	нет
Искать авиабилеты внутри поездки	да	да	нет	нет
Вручную сохранить рейс / импортировать активность	да	да	нет	нет

Примечание: «Собственный долг» означает, что fromMemberId связан с авторизованным пользователем. Для организатора действует то же ограничение

4. Правила безопасности и проверки доступа.

- Все публичные операции с поездкой требуют действительного JWT; C# backend определяет текущего пользователя из токена, а не из переданного клиентом userId.
- Перед работой с tripId Backend проверяет, существует ли поездка и есть ли у пользователя право на действие. Pending и Declined не предоставляют обычного доступа к содержимому поездки.
- Для расхода paidByMemberId и каждый memberId в splits должны принадлежать указанной поездке; сумма долей обязана совпадать с общей суммой.
- Погашение задолженности фиксируется вручную: зарегистрированный должник подтверждает свой перевод, а виртуального должника — только Owner. Повтор подтверждения не должен списывать баланс повторно.
- Приглашение отправляется только существующему зарегистрированному пользователю, идентифицированному по номеру телефона либо привязанному email. Виртуальный участник создаётся отдельным действием.
- Python/FastAPI не проверяет пользовательский JWT и не предоставляет доступ к поездкам. Доступ проверяет основной .NET API до межсервисного вызова.